

EXAMEN DE SEGURIDAD EN EL DISEÑO DE SOFTWARE

PRUEBA FINAL DE LA ASIGNATURA

Nombre y apellidos: Alejandro Castro Santa Grupo: 2 Fecha: 14/06/2026
DNI: 24512671A

1. ¿Qué es el principio de mínimo privilegio y por qué es importante en el diseño de software? (0,5 puntos)

Consiste en que cada componente o módulo de software únicamente tiene que tener acceso a los elementos estrictamente necesarios. No debe disponer de privilegios de más. Este principio es imprescindible porque un componente puede actuar de manera inesperada si tiene demasiados permisos o herramientas que puede utilizar.

2. Explica qué es una inyección SQL, cómo puede explotarse y qué medidas de diseño se deben aplicar para prevenirla. (2 puntos)

Una inyección SQL consiste en que un atacante consigue que el sistema interprete una entrada suya (por ejemplo introducida en un campo de un formulario) como parte de instrucciones SQL que ejecuta el sistema. Si no se previene adecuadamente el atacante podría lograr llevar a cabo acciones malignas como por ejemplo borrar información de una base de datos.

Se previene saneando los campos de entrada que tiene el usuario, realizando validaciones y nunca suponiendo que la información que introduce el usuario es de fiar y que directamente el ~~usuario~~ ^{sistema} puede utilizarla para ejecutar acciones.

3. ¿Qué diferencia hay entre autenticación y autorización? (0,5 puntos)

La autenticación está relacionada con la acción del usuario para acceder a un sistema. Normalmente se lleva a cabo ~~se~~ a través de un formulario de login o introduciendo ciertas credenciales. La autorización, en cambio, tiene que ver con que si un usuario o sistema tiene permiso para acceder a algún recurso o realizar alguna acción.

4. ¿Qué es el modelado de amenazas (threat modeling) y en qué fase del desarrollo debe realizarse? (1 punto)

Consiste en llevar a cabo un análisis de las posibles amenazas y riesgos que pueden comprometer el sistema que se quiere desarrollar. En concreto hay que hacer un estudio de las prioritarias que se quieren mitigar. Esto hay que hacerlo desde la fase de diseño, sin picar ni una sola línea de código hasta que no se hayan determinado. La seguridad siempre se tiene que tener en cuenta desde el diseño, si no las consecuencias pueden ser catastróficas.

5. Describe qué es la defensa en profundidad (defense in depth) como estrategia de seguridad y pon al menos tres ejemplos de capas que se pueden implementar en una aplicación web. (2 puntos)

La defensa en profundidad parte de la premisa de que cualquier control de seguridad puede fallar o ser evadido. En lugar de confiar en una única barrera fuerte se despliegan múltiples capas de defensa independientes, de modo que si un atacante atraviesa una, todavía se encuentra con otras.

En una aplicación web, por ejemplo, se pueden implementar estas 3:

1. Capa de perímetro y red. En forma de firewall → (WAF) que bloquea patrones de ataque.
2. Capa de transporte. Todo el tráfico viaja cifrado mediante HTTPS/TLS.
3. Capa de autenticación. Mecanismos de autenticación robustos (MFA) o RBAC.

6. ¿Qué es el OWASP Top 10 y para qué sirve en el contexto del diseño seguro? (1 punto)

Se trata de un ranking de las 10 vulnerabilidades más explotadas o populares ~~por~~ en un determinado momento. Sirve para que el desarrollador tenga presentes las amenazas más relevantes que pueden comprometer su sistema, de manera que pueda prevenirlas ya desde la fase de diseño.

7. Explica qué es un ataque de tipo Cross-Site Scripting (XSS), cuál es su impacto potencial y qué técnicas de diseño y desarrollo se deben emplear para mitigarlo. (2 puntos)

Un ataque XSS consiste en que el atacante consigue ejecutar JavaScript malicioso en el cliente web de algún usuario. Esto se puede conseguir a través de la URL, infectando el servidor (serviría el JS malicioso al cliente) o de otras maneras indirectas. Es muy peligroso y, por ejemplo, puede hacer que el usuario sea redirigido a sitios externos con malware o robarle información de cookies.

Para mitigarlo, hay que llevar a cabo una validación estricta de las entradas del usuario (saneamiento) y emplear Content Security Policy (CSP).

8. ¿Qué es el cifrado en tránsito y en reposo, y por qué ambos son necesarios? (1 punto)

El cifrado en tránsito tiene que ver con la confidencialidad del mensaje cuando este se transmite, de modo que se cifra dicho mensaje para que nadie ajeno a la transmisión pueda entenderlo. Por otro lado, el cifrado en reposo se manifiesta cuando los datos se cifran en un servidor, en descanso, para que si un atacante consigue acceder, no ~~pueda~~ pueda robar la información disponible, que puede ser sensible.

Ambos son necesarios para garantizar la seguridad de un sistema que trabaja con envíos, recepción y almacenamiento de datos. Son medidas necesarias en cualquier sistema actual para dificultarle al atacante que pueda comprometerlo.